

Technische Hochschule Deggendorf

Fakultät Angewandte Informatik

Studiengang Bachelor Cyber-Security

Kurs: Security Engineering – SS 2026

Themenanmeldung

Secure DevOps (DevSecOps) – Sicherheitstechnische Betrachtung automatisierter CI/CD-Pipelines

Vorgelegt von:

Christof Renner (22301943)
Manuel Friedl (12306626)

Betreuer:

Prof. Dr. Martin Schramm

Datum: 29. April 2026

Ausgangslage und Motivation

Moderne Softwareentwicklung basiert auf hochgradig automatisierten Build-, Test- und Deployment-Prozessen. Diese CI/CD-Pipelines sind tief in cloud-native Infrastrukturen integriert und verfügen über weitreichende Zugriffsrechte auf sensible Ressourcen wie Secrets, Container-Registries und Produktionsumgebungen. Angriffe auf Softwarelieferketten – etwa SolarWinds (2020), Codecov (2021) oder zuletzt `tj-actions/changed-files` (2025) – belegen, dass der Entwicklungsprozess selbst zu einem primären Angriffsziel geworden ist. Im Sinne des Security Engineering soll daher nicht ein einzelnes Tool, sondern die sicherheitstechnische Analyse des gesamten Pipeline-Systems im Vordergrund stehen.

Zielsetzung

Ziel der Arbeit ist eine systematische sicherheitstechnische Betrachtung einer repräsentativen CI/CD-Pipeline. Im Mittelpunkt stehen die Identifikation schützenswerter Assets (Quellcode, Build-Artefakte, Secrets, Deployment-Credentials), relevanter Trust Boundaries sowie eines mehrstufigen Angreifermodells. Darauf aufbauend werden zentrale Bedrohungen je Pipeline-Stufe herausgearbeitet, geeignete Schutzmechanismen abgeleitet und ihre Wirksamkeit kritisch bewertet.

Methodisches Vorgehen

Zunächst wird eine prototypische, container-basierte Pipeline modelliert, um sicherheitsrelevante Übergänge und Angriffsflächen sichtbar zu machen. Anschließend erfolgt eine strukturierte Bedrohungsanalyse auf Basis von STRIDE, ergänzt um eine Validierung gegen einschlägige Industrie-Frameworks. Aus den identifizierten Bedrohungen werden technische und organisatorische Sicherheitsmechanismen abgeleitet – etwa zu Identitäts- und Zugriffsmanagement, Supply-Chain-Integrität, Artefakt-Signierung und kontrollierten Deployment-Prozessen. Begleitend wird ein praktischer Prototyp auf einer modernen Pipeline-Plattform aufgebaut, der die wesentlichen Maßnahmen demonstrierbar macht. Abschließend wird die Pipeline anhand etablierter Reifegrad- und Posture-Modelle (z. B. SLSA, OpenSSF Scorecard) evaluiert.

Erwarteter Mehrwert

Die Arbeit soll zeigen, wie sich ein moderner DevOps-Prozess im Sinne des Security Engineering nicht nur funktional, sondern auch methodisch absichern lässt. Über die rein technische Betrachtung hinaus werden insbesondere die Anreizstrukturen adressiert: Welche Mechanismen sind nicht umgehbar, welche werden in der Praxis ausgehebelt, und wo bleibt der Faktor Mensch trotz aller Automatisierung ausschlaggebend? Das angestrebte Ergebnis ist ein nachvollziehbares und praxisnahes Sicherheitskonzept, das typische Bedrohungen einer CI/CD-Pipeline systematisch erfasst, Gegenmaßnahmen begründet und verbleibende Restrisiken transparent macht.